

## TRAVAUX PRATIQUES

# Élaborer et mettre en œuvre des stratégies de cybersécurité et de protection des données

## 0. Cadre du TP

### Le projet: « HelioMed »

Vous travaillez pour HelioMed, une PME qui édite une plateforme web de prise de rendez-vous médicaux. L'application est en Python (API Flask) derrière un reverse proxy Nginx, avec une base PostgreSQL, hébergée sur deux serveurs Linux (un frontal, un applicatif/BDD). Les patients saisissent des données de santé (RGPD, données sensibles). Une application mobile consomme l'API. L'équipe est en télétravail et déploie via Git.

Ce périmètre est **le même pour les cinq exercices**. Vous n'inventez donc pas un « projet fictif » différent à chaque exo : vous approfondissez HelioMed jour après jour. Tout ce que vous produisez doit rester cohérent d'un exercice à l'autre.

### Ce que vous devez installer (poste de travail)

Chaque installation doit être accompagnée d'une capture montrant la commande de version et sa sortie.

| Outil                            | Rôle dans le TP                                 | Vérification attendue                                               |
|----------------------------------|-------------------------------------------------|---------------------------------------------------------------------|
| VirtualBox ou VMware Workstation | Héberger les 2 VM Linux (frontal + applicatif)  | 2 VM Debian/Ubuntu qui démarrent et se pinguent                     |
| Docker + Docker Compose          | Déployer HelioMed et les outils de sécurité     | <code>docker --version</code> / <code>docker compose version</code> |
| Git + un compte GitLab/GitHub    | Versionner le projet et les rendus              | <code>git --version</code> + dépôt créé                             |
| OWASP ZAP                        | Scan de vulnérabilités web (DAST)               | ZAP démarre, scan passif OK                                         |
| Nmap                             | Cartographie réseau et découverte de services   | <code>nmap -sV</code> sur la VM frontale                            |
| Trivy                            | Scan de vulnérabilités images/dépendances (SCA) | trivy image sur un conteneur                                        |
| Wazuh (ou Suricata + ELK léger)  | Détection d'incidents / SIEM-HIDS               | Agent qui remonte des alertes                                       |
| Gophish                          | Simulation de phishing (Ex.3 sensibilisation)   | Campagne de test envoyée en local                                   |
| OpenVAS / Greenbone (option)     | Scan de vulnérabilités réseau                   | Un scan lancé sur une VM                                            |

#### Environnement

Utilisez OWASP Juice Shop + DVWA comme cibles d'entraînement représentant les composants d'HelioMed). Montez tout dans un réseau isolé.

- **Fichiers de configuration réels** (nginx.conf, docker-compose.yml, règles de pare-feu, politiques...) commités dans Git avec un historique de commits progressif.
- **Journal de bord (logbook)** : à chaque étape, 2-3 lignes indiquant ce que vous avez fait, ce qui a échoué, comment vous l'avez corrigé.
- **Adresses IP, ports, hashes, identifiants de vos machines** doivent apparaître et être cohérents entre tous les documents.

## Exercice 1 — Analyse de l'environnement de sécurité

**Format :** binôme. **Objectif :** identifier les actifs, les vulnérabilités, les menaces, évaluer les risques et poser les objectifs de sécurité d'HelioMed, puis choisir vos outils d'analyse.

### Étape 1.1 — Cartographier avant d'analyser (pratique)

1. Déployez HelioMed (ou les cibles fournies) dans votre labo isolé. Notez les IP des 2 VM.
2. Depuis une machine du labo, lancez une découverte réseau : `nmap -sV -sC -oN scan_helio.txt <plage>`. Identifiez les services, ports et versions exposés.
3. Lancez un scan passif OWASP ZAP sur l'interface web. Exportez la liste des alertes.
4. Lancez trivy sur l'image applicative et notez les CVE critiques/hautes.

### Étape 1.2 — Registre des actifs et vulnérabilités

À partir de vos découvertes réelles (pas d'une liste générique), remplissez un registre d'actifs. Classez chaque actif par sensibilité (RGPD : données de santé = sensibles).

| Actif              | Type   | Sensibilité      | Vulnérabilité constatée      | Source (outil) |
|--------------------|--------|------------------|------------------------------|----------------|
| ex. BDD PostgreSQL | Donnée | Critique (santé) | à compléter depuis vos scans | nmap/Trivy     |
| ...                |        |                  |                              |                |

### Étape 1.3 — Menaces et analyse de risque

Modélisez les menaces avec **STRIDE** (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) sur au moins 6 actifs. Puis cotez le risque avec une matrice **Vraisemblance × Impact** (échelle 1 à 4), et positionnez la méthode **EBIOS Risk Manager** (ANSSI) : identifiez au moins 3 sources de risque et 3 scénarios stratégiques.

| Menace (STRIDE)            | Actif visé | Vraisemb. (1-4) | Impact (1-4) | Risque     | Traitement envisagé         |
|----------------------------|------------|-----------------|--------------|------------|-----------------------------|
| ex. Information disclosure | BDD santé  | 3               | 4            | 12 — Élevé | Chiffrement + cloisonnement |
| ...                        |            |                 |              |            |                             |

### Étape 1.4 — Objectifs de sécurité et choix d'outils

- Formulez 5 objectifs de sécurité mesurables (ex. « aucun service exposé sans authentification », « toute donnée de santé chiffrée au repos »), rattachés aux 3 critères DICP (Disponibilité, Intégrité, Confidentialité, Preuve/traçabilité).
- Justifiez le choix de vos outils d'analyse (pourquoi ZAP plutôt que..., pourquoi Trivy...) en fonction du périmètre HelioMed.

#### Livrable Ex.1 (à déposer 12h30)

1 note d'analyse (registre d'actifs + STRIDE + matrice de risque + EBIOS + 5 objectifs), 4 à 6 pages, les fichiers de sortie bruts des outils (scan\_helio.txt, exports ZAP/Trivy), logbook du binôme avec la part IA explicitée.